Data privacy and security note (1 page)

Scope.

Udyam Digital handles business and signatory data for KYC. Although the pack is synthetic, it is treated as real personal data under the **DPDP Act, 2023**: consent, purpose limitation, data minimisation, storage limitation, security and erasure.

1. Collect only what each step needs

- Onboarding: business name/type, city, headcount, sites, connectivity, budget, optional GSTIN, contact name and mobile. No documents, no ID numbers.
- KYC: exactly four documents - GST certificate, Udyam certificate, signatory ID, utility bill (address proof) - and only after consent. Nothing is used for marketing or shared with third parties.
- The advisor chat stores what the customer types; it is never sent to the LLM together with identifiers or documents (only the typed message and a short history are sent when a key is configured).

2. Consent and purpose

A dedicated consent screen precedes any upload: it lists the three purposes (verify identity/registrations against registries, match address proof, create and activate the account), the retention period, and the right to delete. Consent is recorded with timestamp, notice version, purposes and retention days; uploads are refused without it. A customer can decline and verify through the field team instead.

3. Mask identifiers

GSTIN, Udyam number, ID number and consumer number are masked in every API response and screen (`27**1ZP`) and never written to logs (logs carry case id, document type and a hash prefix). Registry lookups return full records only to the lookup endpoint that emulates the public registry.

4. Security

- Uploaded files are encrypted at rest (Fernet/AES + HMAC) under random file names, outside the web root; extracted fields and declared identifiers are stored encrypted in the database.
- bcrypt password hashes, JWT sessions, role checks, owner-scoped queries (other users' orders return 404), upload validation (magic bytes, 8 MB, PNG/JPG), rate limits, parameterised queries, generic error bodies.
- Secrets come from environment variables; the LLM key lives only on the server; the browser talks to a same-origin proxy and never learns the backend address.
- Documents never leave the server: OCR runs locally (ONNX), registry checks use the supplied mock files.

5. Retention and erasure

Documents and extracted data are **deleted automatically after 30 days** (`DOCUMENT_RETENTION_DAYS`; purge runs at startup and via an admin job) - the purge date is shown next to every upload. The customer can delete all documents and withdraw consent at any time (`DELETE /api/orders/{id}/kyc`), which removes files, extracted data and the declared identifiers and marks consent withdrawn. The KYC *outcome* (status, issue codes) is kept with the order as the audit record.

6. Human oversight and fairness

Rejections and mismatches always state the reason and the fix. Borderline cases (`needs_review`) go to a person - the system does not auto-reject on fuzzy matches. Eligibility and prices are rule-based and reproducible, so decisions can be explained and audited; the LLM cannot alter them.

7. Known gaps (prototype)

In-memory rate limiter (single process) · encryption key derived from the JWT secret unless `ENCRYPTION_KEY` is set (set it in production, ideally from a KMS) · no DigiLocker consent artefact / e-sign yet · no formal DPIA, breach-notification workflow or data-processor agreement with the LLM provider · backups and replicas are not covered by the purge job.